Architecture (one page)

Implemented = built and tested here. **Proposed** = design only. Python computes every number; the model writes and a second model reviews.

Structure

- `clients/<id>/config.yaml` holds each client's workbook path, sheet and label names, account mapping and fiscal year. A new client needs a config file, not code (`xyz` is the proof).
- `src/abc_workbook_adapter.py` parses wide monthly sheets and computes totals, MoM, TTM, margins, categories, one-offs and cash runway. `src/run_client.py` runs one client and writes `outputs/<client>/`.
- `src/monthly_review.py` builds the review packet and the Excel sign-off pack. `.claude/` holds skills, the `finance-reviewer` agent, `/monthly-analysis`, and hooks.
- `03_evals/` has 22 golden cases, a commentary grader, a mutation test and a 32-fault robustness suite; `tests/` has the unit tests. Failures found are logged in `03_evals/evals_caught.md`.

Context: what the model sees

Only the packet JSON for one client and month, plus skill instructions. It never gets the workbook, `.env` files or another client's folder. Commentary is checked two ways: a deterministic grader (every number, the 3 top movements, cash risk) and an LLM reviewer (causes, unsupported claims). The grader cannot judge wording; the reviewer can be wrong, so a human signs off. Sign-off cells are left blank.

Hosting

- **Implemented:** one Windows machine; Claude Code starts the QuickBooks MCP server over stdio. No listener, no shared service.
- **Proposed:** a service identity, one server process and token store per client, secrets in a manager, audit log, alerts. Details in `01_connection/connection_decision.md`.
- QuickBooks is read-only and sandbox-only. Its sample data is **not** an input to the analysis, which reads the supplied workbooks.

Ten-client isolation

- **Implemented:** per-client config and `outputs/<client>/`. During a run an in-process audit hook blocks reads of other clients' folders and writes outside the client's own output folder (13 tests, including path-spelling bypasses). Name-based hooks block `.env`, token and credential files.
- **Proposed:** a separate OAuth grant, token store and server process per client; realm check at connect time; one Claude session per client; per-client OS accounts or containers; retention and deletion rules.
- Only two clients exist. Ten is untested, and no QuickBooks grant exists for more than the one sandbox.

Credential security

- **Implemented:** QuickBooks MCP runs with the write, update and delete flags set to `true` (disabled), so it is read-only. Secrets stay outside the repo, and a hook blocks reads of `.env` and token files. The final run includes a secret scan.
- **Not applied:** a separate write credential for the loader, kept apart from the read-only analysis credential.
- **Proposed:** per-client OAuth grants and token stores in team hosting (see Ten-client isolation).

Memory

- `CLAUDE.md` = standing rules; skills = procedure; per-client `config.yaml` = client facts. No cross-client memory.

What breaks first

1. **Credential upkeep.** Ten grants means ten browser logins, and refresh tokens rotate and expire. One stale or doubly-refreshed token silently stops a client. No monitoring exists.
2. **Isolation is a convention, not a boundary.** The audit hook covers this Python process only. Claude's own tools run as the same OS user and can read any file their path-name does not trip. Two clients in one session mix context.
3. **Account mapping.** Each client needs a hand-built mapping that someone must review. Unmapped accounts are reported, not guessed, but the mapping is judgement.
4. **Layout assumptions.** The parser expects one wide sheet with month columns and totals; a differently built export fails or, worse, mislabels columns. The reviewer step does not catch parsing errors.
5. **Review quality.** The reviewer is an LLM and varies between runs. The deterministic checks do not cover causes or unusual items.
6. **One machine.** No backup, concurrency control or audit trail beyond files in `outputs/`.